

HTTP Security Headers

A02:2025 — Security
Misconfiguration

Headers HTTP

- **Header HTTP:** informação adicional (metadados de rede) enviadas em uma requisição ou resposta HTTP

- **Resposta HTTP:**

- HTTP/1.1 200 OK
Content-Type: application/json
Content-Length: 32

Headers (Cabeçalho)

- ```
{
 "mensagem": "Olá"
}
```

Paylload

- Headers informam o cliente ou servidor sobre informações da aplicação
  - **Incluem políticas de segurança**

# Middleware FastAPI

- **Middleware:** código que fica “no meio do caminho” entre a requisição que chega e a resposta que sai
  - **Fluxo:** Cliente→Middleware→Rota FastAPI→Middleware→Cliente
- **Middleware pode inspecionar ou modificar a requisição**
  - antes da rota ser gerada
  - ou depois da rota ser gerada
- **Ideal:** aplicar uma regra para toda a aplicação, sem repetir código
  - Exemplo: enviar quanto tempo o servidor demorou para processar a requisição
    - **Header X-Process-Time** em cada requisição
  - Sem middleware tem que repetir código em cada requisição



# Middleware FastAPI

- **Sintaxe:**
  - ```
@app.middleware("http")
async def nome_middleware(request: fastapi.Request,
call_next):
    # código executado antes da rota
    response = await call_next(request)
    # código executado depois da rota
    return response
```

 - **request:** requisição que chegou
 - **call_next:** função que continua o processamento até a rota
 - **@app.middleware("http"):** Define que o middleware intercepta requisições HTTP
 - **response = await call_next(request):** executa a rota e recebe a resposta dela



Exemplo Middleware para X-Process-Time

- Modelos pydantic para Requisição e Validação de Predição:

- ```
class PredictionRequest(BaseModel):
 message: str
```

```
class PredictionResponse(BaseModel):
 message: str
 intent: str
```

```
class PredictionValid(BaseModel):
 message: str
 valid: str
```



# Exemplo Middleware para X-Process-Time

- Rota para predição com contagem de tempo:

- ```
@app.post("/predict")
def predict(predictionRequest: PredictionRequest, response: Response):
    start = time.time()
    predictionResponse = PredictionResponse(
        message=predictionRequest.message,
        intent='cancelamento'
    )
    final = time.time()
    response.headers['X-Process-Time'] = str(final - start)
    return predictionResponse
```

- Rota para validação de predição com contagem de tempo:

- ```
@app.post("/valid")
def valid(predictionRequest: PredictionRequest, response: Response):
 start = time.time()
 predictionResponse = PredictionValid(
 message=predictionRequest.message,
 valid='Válido' if len(predictionRequest.message) > 5 else "Inválido"
)
 final = time.time()
 response.headers['X-Process-Time'] = str(final - start)
 return predictionResponse
```



# Exemplo Middleware para X-Process-Time

- Middleware com contagem de tempo em main.py:

- ```
@app.middleware("http")
async def process_time(request: fastapi.Request, call_next):
    start = time.time()
    response = await call_next(request)
    final = time.time()
    response.headers["X-Process-Time"] = str(final - start)
    return response
```

- Rotas de predição e validação limpas:

- ```
@app.post("/predict")
def predict(predictionRequest: PredictionRequest, response: fastapi.Response):
 predictionResponse = PredictionResponse(
 message=predictionRequest.message,
 intent='cancelamento'
)
 return predictionResponse
```

```
@app.post("/valid")
def valid(predictionRequest: PredictionRequest, response: fastapi.Response):
 predictionResponse = PredictionValid(
 message=predictionRequest.message,
 valid='Válido' if len(predictionRequest.message) > 5 else "Inválido"
)
 return predictionResponse
```

# Headers de segurança

- **HSTS (HTTP Strict Transport Security):** Usar HTTPS para acessar este domínio
  - **Exemplo recomendável:**

```
response.headers["Strict-Transport-Security"] =
"max-age=31536000; includeSubDomains"
```
- **X-Frame-Options:** Controla se a página pode ser colocada dentro de uma tag iframe HTML
  - **Exemplo recomendável:**

```
response.headers["X-Frame-Options"] = "DENY"
```
- **X-Content-Type-Options:** evitar MIME sniffing
  - **MIME sniffing:** navegador adivinhar tipo do arquivo e tentar executar
  - **Exemplo recomendável:**

```
response.headers["X-Content-Type-Options"] = "nosniff"
```



# Headers de segurança

- **Content-Security-Policy: quais fontes de conteúdo podem ser carregadas e executadas pela página**
  - `default-src 'self'` → padrão: só o próprio domínio
  - `script-src 'self'` → JavaScript só do próprio domínio
  - `style-src 'self'` → CSS só do próprio domínio
  - `img-src ...` → imagens do próprio domínio e de `images.exemplo.com`
  - **Exemplo recomendável (pode afetar swagger):**  
`response.headers["Content-Security-Policy"] = "default-src 'self'"`



# CORS



# Middleware pronto FastAPI

- **Middleware pronto FastAPI:** middleware já implementado e pronto para uso
  - **CORSMiddleware:** controla quais origens podem acessar sua API pelo navegador
  - **GZipMiddleware:** comprime respostas maiores para reduzir a quantidade de dados trafegados
  - **HTTPSRedirectMiddleware:** força o acesso por HTTPS
- **Adicionar middleware pronto:**
  - ```
app.add_middleware(  
    MiddlewareClass,  
    parametro1=valor1,  
    parametro2=valor2  
)
```



CORS

- **CORSMiddleware:** Controla quais origens podem acessar sua API pelo navegador
 - **Principais parâmetros:**
 - **allow_origins:** lista de origens que podem acessar sua API pelo navegador
 - **allow_methods:** lista de métodos HTTP permitidos para requisições CORS
 - **allow_headers:** lista de headers que o frontend pode enviar
 - **allow_credentials:** booleano indicando se navegador pode enviar credenciais em requisições entre origens, como cookies e headers de autenticação em certos cenários

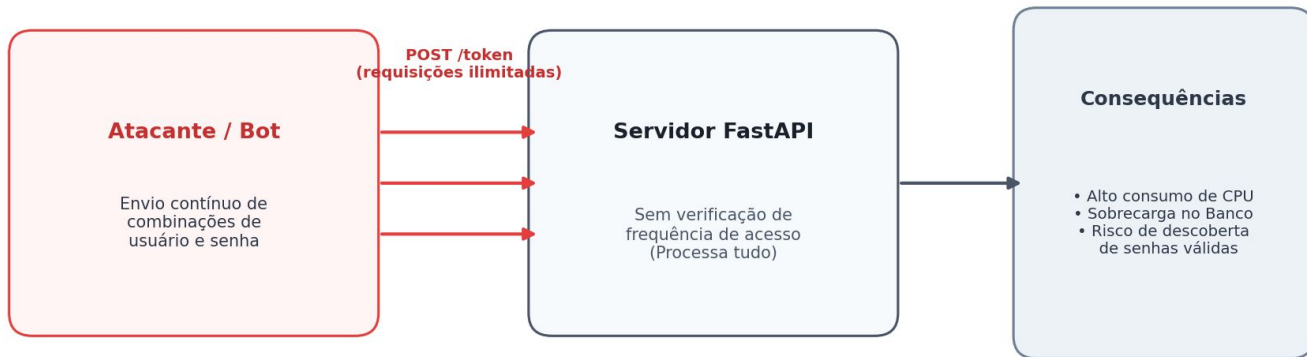


Brute Force e Rate Limiting



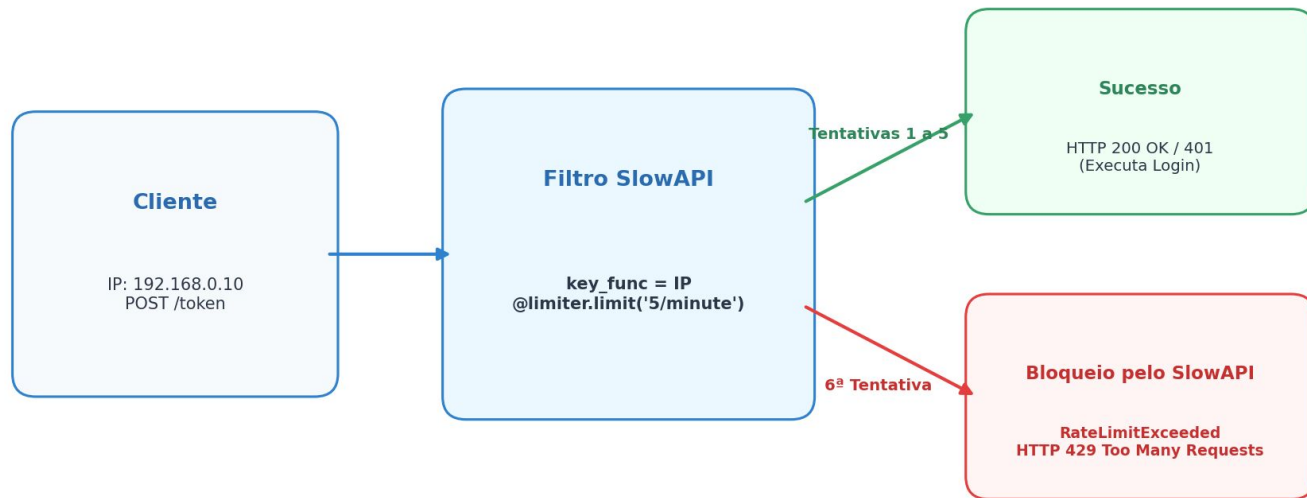
Brute Force Attack

- **Brute Force Attack:** atacante tenta descobrir uma senha tentando todas as combinações possíveis
 - Sem nenhum controle, um atacante pode enviar centenas ou milhares de tentativas
 - **Exemplo:**
 - `POST /token` com usuário e senha
 - `admin / 123`, `admin / admin`, `admin / password`,
`admin / 123456`, ...



Rate Limiting

- **Rate limiting:** técnica que limita quantas requisições um cliente pode fazer durante determinado período
 - **Exemplo:**
 - **Regra:** 5 requisições por minuto
 - **Execução:** 1ª req → permitida, 2ª req → permitida, 3ª req → permitida, 4ª req → permitida, 5ª req → permitida, **6ª req → bloqueada,**



SlowAPI

- **SlowAPI:** biblioteca de rate limiting utilizada com FastAPI e Starlette
 - **Permite definir limites diretamente nos endpoints**
- **Instalação:** `pip install slowapi`
- **Criação do limiter:**
 - **Imports:**
 - `from slowapi import Limiter`
 - `from slowapi.util import get_remote_address`
 - **Classe Limiter:**
 - `limiter = Limiter( key_func=... )`
 - **limiter:** objeto utilizado para limitar
 - **key_func:** define como os clientes serão identificados
 - **get_remote_address:** cliente é identificado pelo seu endereço IP
 - **Exemplo:**
 - `limiter = Limiter(key_func=get_remote_address)`



SlowAPI

- **Aplicação do limite:**
 - `@limiter.limit(str_limite)`
 - `str_limite`: string contendo código de restrição
 - **Exemplos:**
 - `"5/minute"`, `"10/minute"`, `"100/hour"`, `"1000/day"`
 - Decorador aplicado entre decorador de rota e definição de função de rota
 - Envolve a função do endpoint e verifica o limite antes de permitir sua execução
 - Não retorna algo que normalmente é utilizado diretamente no código
- **Request obrigatório:**
 - `def func_route ( request: Request, ... ):`
 - SlowAPI necessita da request como parâmetro da rota

SlowAPI

- **Configuração no FastAPI:**
 - **Importar exceção:**
 - `from slowapi import _rate_limit_exceeded_handler`
 - **Importar tipo de erro:**
 - `from slowapi.errors import RateLimitExceeded`
 - Transforma a exceção em uma resposta HTTP apropriada
HTTP 429 Too Many Requests
 - **Configurar estado FastAPI:**
 - `api.state`: permite armazenar objetos relacionados à aplicação
 - `add_exception_handler(exception, handler)`:
 - `exception`: tipo de exceção a ser tratada
 - `handler`: Função executada quando essa exceção ocorrer
 - Registra uma função para tratar determinado tipo de exceção



Configuração de RateLimiting com SlowAPI

- Configuração do limitador na rota de predição:

- ```
from fastapi import Request
from slowapi import Limiter
from slowapi.util import get_remote_address

from fastapi import APIRouter, Depends, HTTPException
from sqlmodel import Session, select

from database import get_session
from models.prediction_sql_model import Prediction
from models.user_sql_model import User
from security.dependencies import get_current_user

router = APIRouter()
limiter = Limiter(key_func=get_remote_address)

@router.get("/predicitons")
@limiter.limit("5/minute")
def get_all_predicitons(
 request: Request,
 session: Session = Depends(get_session),
 ...
```

# Configuração de RateLimiting com SlowAPI

- Configuração do limitador na rota de predição:

```
from fastapi import Request
from slowapi import Limiter
from slowapi.util import get_remote_address
```

Imports

```
from fastapi import APIRouter, Depends, HTTPException
from sqlmodel import Session, select
```

```
from database import get_session
from models.prediction_sql_model import Prediction
from models.user_sql_model import User
from security.dependencies import get_current_user
```

```
router = APIRouter()
limiter = Limiter(key_func=get_remote_address)
```

Limitador

```
@router.get("/predicitons")
@limiter.limit("5/minute")
def get_all_predicitons(
 request: Request,
 session: Session = depends(get_session),
 ...
```

Configuração da  
rota

# Configuração de RateLimiting com SlowAPI

- Configuração do FastAPI:

- ```
from slowapi import _rate_limit_exceeded_handler
from slowapi.errors import RateLimitExceeded
from routes.prediction_route import limiter as prediction_limiter

from fastapi import FastAPI
from sqlmodel import SQLModel

from database import engine
from routes.prediction_route import router as prediction_router

app = FastAPI()
app.state.limiter = prediction_limiter
app.add_exception_handler(
    RateLimitExceeded,
    _rate_limit_exceeded_handler
)
...
```

Configuração de RateLimiting com SlowAPI

- Configuração do FastAPI:

```
from slowapi import _rate_limit_exceeded_handler
from slowapi.errors import RateLimitExceeded
from routes.prediction_route import limiter as prediction_limiter
```

Imports

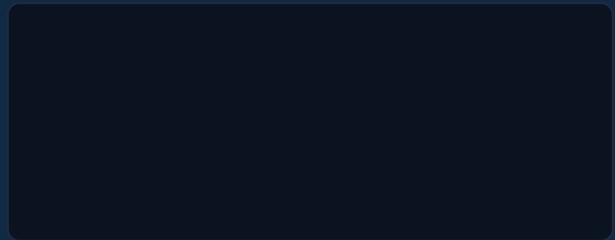
```
from fastapi import FastAPI
from sqlmodel import SQLModel
```

```
from database import engine
from routes.prediction_route import router as prediction_router
```

```
app = FastAPI()
app.state.limiter = prediction_limiter
app.add_exception_handler(
    RateLimitExceeded,
    _rate_limit_exceeded_handler
)
...
```

Tratamento de
exceção

Scan passivo OWASP ZAP



OWASP ZAP

- **OWASP ZAP (Zed Attack Proxy):** ferramenta gratuita e open source para testar a segurança de aplicações web e APIs
 - Proxy entre o cliente e a aplicação. Assim, consegue observar as requisições e respostas HTTP e procurar possíveis problemas de segurança
- **Download ZAP:** <https://www.zaproxy.org/download/>
- **Scan Passivo:** ZAP apenas observa o tráfego que já está acontecendo e analisa as mensagens
- **Scan Ativo:** Envia requisições próprias, tenta explorar possíveis falhas e Pode alterar comportamento/dados



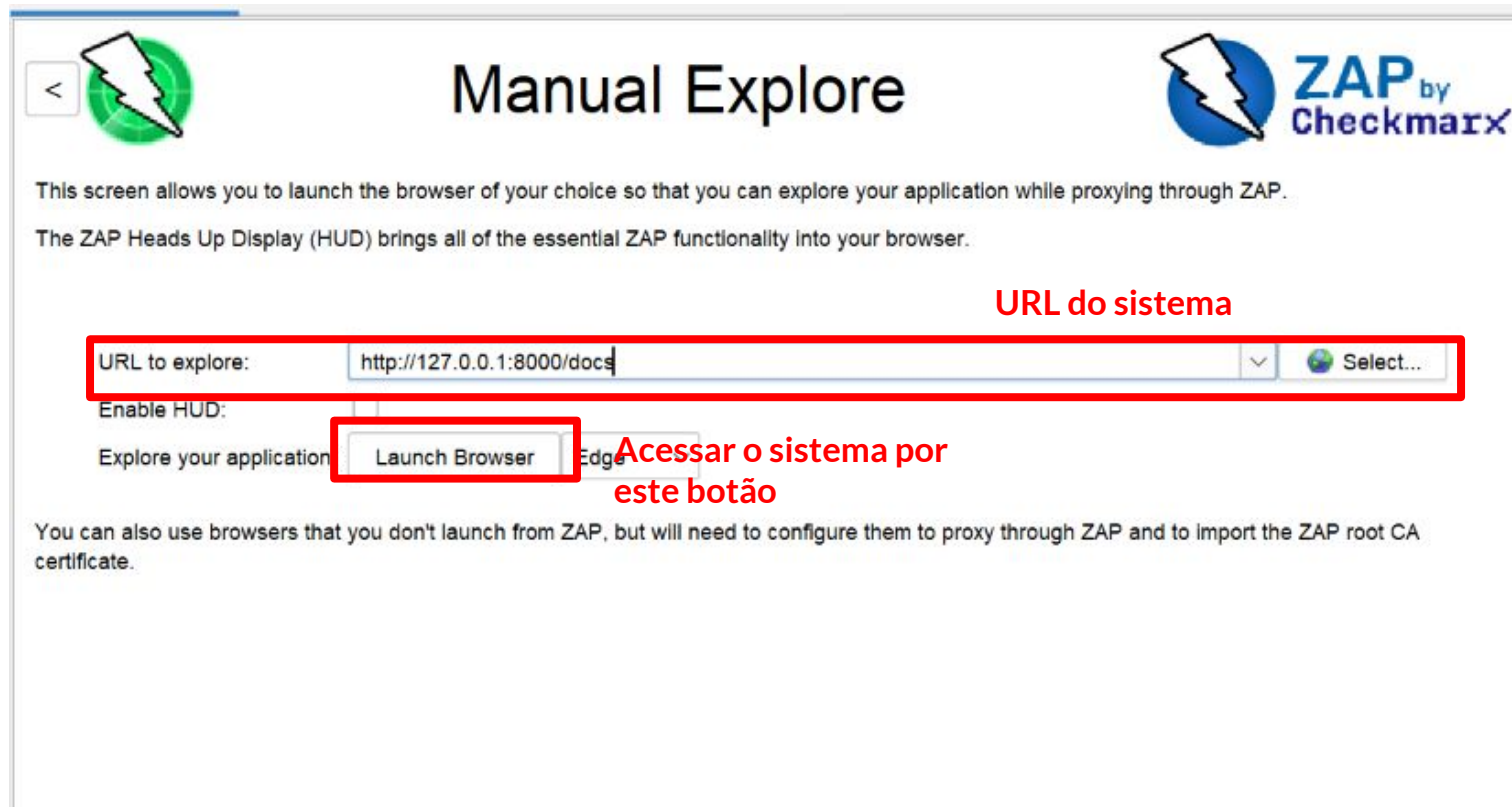
OWASP ZAP Scan Passivo

- **OWASP ZAP (Zed Attack Proxy):** ferramenta gratuita e open source para testar a segurança de aplicações web e APIs
 - Proxy entre o cliente e a aplicação. Assim, consegue observar as requisições e respostas HTTP e procurar possíveis problemas de segurança
- **Download ZAP:** <https://www.zaproxy.org/download/>
- **Scan Passivo:** ZAP apenas observa o tráfego que já está acontecendo e analisa as mensagens
- **Scan Ativo:** Envia requisições próprias, tenta explorar possíveis falhas e Pode alterar comportamento/dados

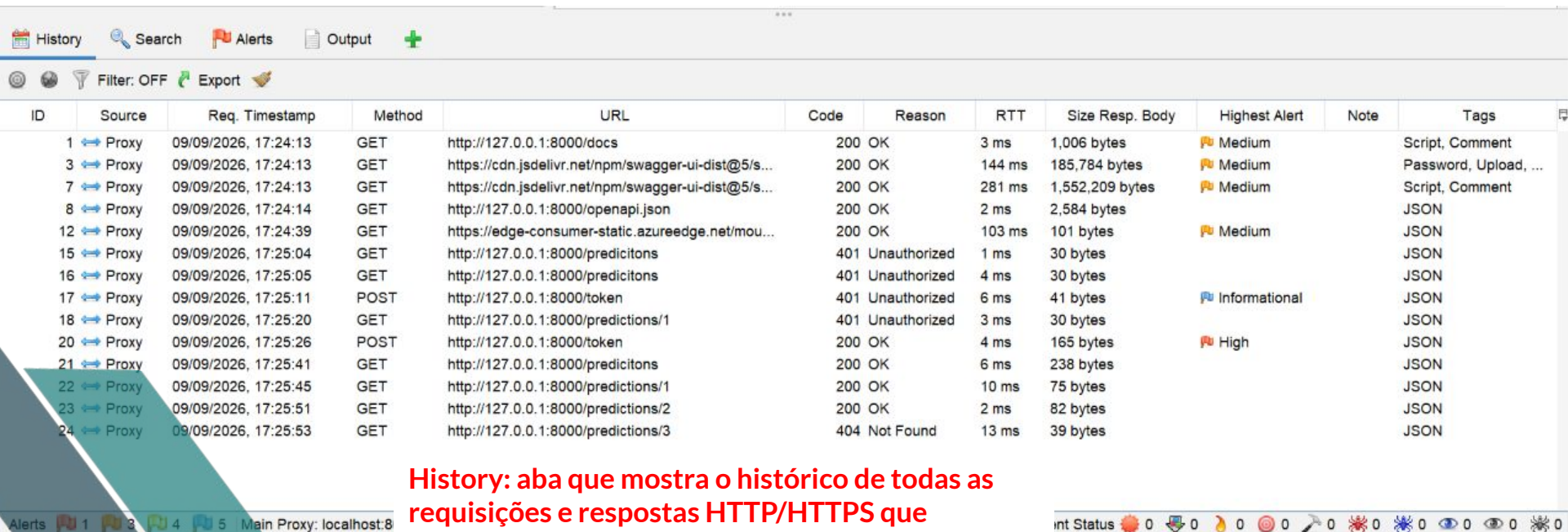




OWASP ZAP Scan Passivo



OWASP ZAP Scan Passivo



The screenshot displays the OWASP ZAP interface with the 'History' tab selected. The main area shows a table of 24 HTTP requests. The table columns are: ID, Source, Req. Timestamp, Method, URL, Code, Reason, RTT, Size Resp. Body, Highest Alert, Note, and Tags. The requests include various endpoints like /docs, /swagger-ui-dist, /openapi.json, /predicitions, /token, and /predictions. The 'Highest Alert' column shows alerts ranging from 'Medium' to 'High'. The 'Tags' column lists tags like 'Script, Comment', 'Password, Upload, ...', and 'JSON'.

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
1	Proxy	09/09/2026, 17:24:13	GET	http://127.0.0.1:8000/docs	200	OK	3 ms	1,006 bytes	Medium		Script, Comment
3	Proxy	09/09/2026, 17:24:13	GET	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/s...	200	OK	144 ms	185,784 bytes	Medium		Password, Upload, ...
7	Proxy	09/09/2026, 17:24:13	GET	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/s...	200	OK	281 ms	1,552,209 bytes	Medium		Script, Comment
8	Proxy	09/09/2026, 17:24:14	GET	http://127.0.0.1:8000/openapi.json	200	OK	2 ms	2,584 bytes			JSON
12	Proxy	09/09/2026, 17:24:39	GET	https://edge-consumer-static.azureedge.net/mou...	200	OK	103 ms	101 bytes	Medium		JSON
15	Proxy	09/09/2026, 17:25:04	GET	http://127.0.0.1:8000/predicitions	401	Unauthorized	1 ms	30 bytes			JSON
16	Proxy	09/09/2026, 17:25:05	GET	http://127.0.0.1:8000/predicitions	401	Unauthorized	4 ms	30 bytes			JSON
17	Proxy	09/09/2026, 17:25:11	POST	http://127.0.0.1:8000/token	401	Unauthorized	6 ms	41 bytes	Informational		JSON
18	Proxy	09/09/2026, 17:25:20	GET	http://127.0.0.1:8000/predictions/1	401	Unauthorized	3 ms	30 bytes			JSON
20	Proxy	09/09/2026, 17:25:26	POST	http://127.0.0.1:8000/token	200	OK	4 ms	165 bytes	High		JSON
21	Proxy	09/09/2026, 17:25:41	GET	http://127.0.0.1:8000/predicitions	200	OK	6 ms	238 bytes			JSON
22	Proxy	09/09/2026, 17:25:45	GET	http://127.0.0.1:8000/predictions/1	200	OK	10 ms	75 bytes			JSON
23	Proxy	09/09/2026, 17:25:51	GET	http://127.0.0.1:8000/predictions/2	200	OK	2 ms	82 bytes			JSON
24	Proxy	09/09/2026, 17:25:53	GET	http://127.0.0.1:8000/predictions/3	404	Not Found	13 ms	39 bytes			JSON

Alerts 1 3 4 5 Main Proxy: localhost:8

int Status 0 0 0 0 0 0 0 0 0 0 0 0

History: aba que mostra o histórico de todas as requisições e respostas HTTP/HTTPS que passaram pelo ZAP, permitindo verificar quais endpoints foram acessados, métodos utilizados, códigos de resposta e detalhes completos das mensagens trocadas com a aplicação.

History

Search

Alerts

Output

Alerts (13)

> Authentication Credentials Captured

> Content Security Policy (CSP) Header Not Set

> GET:http://127.0.0.1:8000/docs

> Cross-Domain Misconfiguration (3)

> Sub Resource Integrity Attribute Missing (2)

> Cross-Domain JavaScript Source File Inclusion

> Strict-Transport-Security Header Not Set

> Timestamp Disclosure - Unix (Systemic)

> X-Content-Type-Options Header Missing

> Authentication Request Identified (2)

> Modern Web Application

> Re-examine Cache-control Directives

> Retrieved from Cache (2)

> Session Management Response Identified

Content Security Policy (CSP) Header Not Set

URL: http://127.0.0.1:8000/docs

Risk: Medium

Confidence: High

Parameter:

Attack:

Evidence:

CWE ID: 693

WASC ID: 15

Source: Passive (10038 - Content Security Policy (CSP) Header Not Set)

Alert Reference: 10038-1

Input Vector:

Description:

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered

Other Info:

Alerts  1  3  4  5 Main Proxy: localho

Current Status  0  0  0  0  0  0  0  0  0 

Documentação de descobertas

- **Finding:** nome do problema identificado pelo ZAP. Ex.: Content Security Policy (CSP) Header Not Set.
- **Severidade:** nível de risco atribuído pelo ZAP, normalmente Medium ou High.
- **Confiança:** indica o quanto o ZAP está confiante de que o problema realmente existe, por exemplo Low, Medium ou High.
- **URL afetada:** endpoint ou página onde o problema foi encontrado. Ex.: <http://127.0.0.1:8000/docs>.
- **O que foi detectado:** explique objetivamente o que está faltando ou configurado de forma insegura.
- **Por que é um problema:** descreva o risco de segurança causado por esse finding.
- **Correção realizada:** explique o que você alterou no código ou na configuração para resolver o problema.
- **Validação:** informe que executou novamente o scan para verificar se o finding desapareceu.
- **Risco aceito, se não corrigido:** caso você decida não corrigir, explique tecnicamente por que o risco foi aceito.

Documentação de descobertas

- **Exemplo documentação finding:**

- **Finding: Content Security Policy (CSP) Header Not Set**

Severidade: Medium

Confiança: High

URL afetada:

<http://127.0.0.1:8000/docs>

O que foi detectado:

O OWASP ZAP identificou que a resposta HTTP do endpoint `/docs` não possui o header `Content-Security-Policy` (CSP).

Por que é um problema:

Sem uma política CSP, o navegador não possui restrições explícitas sobre quais origens podem fornecer scripts, estilos, imagens e outros conteúdos. Isso reduz a proteção contra ataques como Cross-Site Scripting (XSS) e injeção de conteúdo malicioso.

Correção realizada:

Foi adicionado o header CSP no middleware da aplicação FastAPI:

```
response.headers["Content-Security-Policy"] = "default-src 'self'"
```

Com isso, por padrão, o navegador passa a permitir o carregamento de recursos somente da própria origem da aplicação.

Validação:

Após a correção, a API deve ser reiniciada e o scan passivo executado novamente no OWASP ZAP. O objetivo é verificar se o alerta `Content Security Policy (CSP) Header Not Set` deixa de aparecer.

